

IDW PMS: Compliance-to-Page Map (v0.1)

Prepared 1 Oct 2026 for the IDW founder. **Working design document, not legal advice.**

Rules below come from secondary summaries found on 1 Oct 2026, not the Gazette text.

A healthcare-data lawyer must review before launch, and no one can honestly promise full compliance from a design document alone.

1. What applies, and from when

Rule	What it requires (as found)	Timing
DPDP Act 2023 + DPDP Rules 2025	Plain-language notice before consent; purpose-specific consent; easy withdrawal; security safeguards; breach notification; retention and erasure; verifiable guardian consent for children; patient rights (access, correction, erasure, grievance)	Board set up 13 Nov 2025; consent-manager registration 13 Nov 2026; main duties from 13 May 2027
ABDM (HDM Policy, HIP/HIU guidelines, M1-M3)	ABHA creation/verification, consent artefacts, FHIR R4 record sharing. ABDM consent is separate from DPDP consent	Needed before any ABDM sharing goes live
CERT-In Directions 2022	Keep ICT logs 180 days in India; report cyber incidents within 6 hours; sync clocks to NIC/NPL time	In force
EHR Standards 2016	Keep electronic records while active and 3 years after death; permanent retention encouraged	In force (guidance)
Record retention	One source cites 3 years from treatment (inpatient) and 2 years (outpatient); it gives no dental-specific period	Confirm with lawyer / Dental Council

To verify with a lawyer (from general knowledge, not checked today): telemedicine rules if teleconsult is added; e-prescription and drug rules; state Clinical Establishments rules; Dental Council advertising rules for clinic listings; GST invoice rules; Aadhaar storage limits.

2. Compliance-to-page map

Requirement	Where it appears in the PMS	Design note
Notice before consent, in the patient's language (DPDP)	Patient registration: notice screen shown before any data entry	Language switch; notice version number stored with consent
Purpose-specific, unbundled consent; refusal must not block care (DPDP)	Registration > Consent step	Separate toggles: clinical care, ABDM record sharing, WhatsApp reminders, marketing, anonymised research. Store who captured it, when, and which notice version
Withdraw consent as easily as giving it	Consent centre (patient) + Consent ledger tab (clinic)	One-tap withdrawal, logged
Children: verifiable guardian consent first; no tracking or targeted ads (DPDP)	Registration: date of birth triggers guardian flow	Guardian name, relationship, ID check; marketing toggles hidden for minors. Important for primary-teeth patients
Access, correction, erasure, grievance (DPDP)	Patient rights requests page + Grievance Officer link in footer of every page	Erasure: acknowledge in writing, cite the retention rule, set a deletion date, keep the audit trail
Retention and erasure	Admin > Retention settings and deletion queue	Clinical records are voided, never hard-deleted (same rule as the odontogram spec)
Security: encryption, access control, logging	Login with roles and MFA; session timeout; Audit and access log page	Hosting in AWS Mumbai; encryption in transit and at rest
Breach handling (DPDP + CERT-In 6 hours)	Admin > Incident register	Timestamps, who was told, CERT-In report, notice to affected patients; breach timings under DPDP to be confirmed by lawyer

Requirement	Where it appears in the PMS	Design note
Logs 180 days in India, NTP time sync	Audit log page; infrastructure item for developer	Not a screen, but the log page reads from it
ABDM: ABHA, care contexts, consent artefacts	Patient record > ABDM tab	ABHA link/verify; sharing consent kept separate from DPDP consent; view and revoke artefacts; FHIR export preview
Third parties (WhatsApp, Razorpay, labs)	Admin > Processor register	Purpose, data shared, breach-notice terms for each
Record integrity and audit trail	Every clinical page	Show last updated by/at and a history view
Data minimisation	Registration fields	Collect only what care needs; ABHA only through the ABDM flow
Grievance Officer, privacy policy, price disclaimer (IDW standard)	Footer of all pages	Already in your standards

3. Proposed page list and build order

Phase A: compliance-critical (build first)

1. Login, roles and MFA
2. Clinic setup (clinic profile, facility ID, Grievance Officer, doctors with registration numbers)
3. Patient registration: notice, then consent, then guardian flow
4. Consent centre and consent ledger
5. Patient record (Patient Info)
6. Odontogram (prototype done)
7. Treatment plan
8. GST invoice

- 9. Patient rights requests
- 10. Audit and access log
- 11. Incident register
- 12. Processor register and retention settings

Phase B: appointments, WhatsApp recalls, ABDM linking (M1) and record sharing (M2), reports.

4. Decisions needed from the founder

- Languages at launch (English plus which others)?
- Will the PMS launch before 13 May 2027? (Recommended: build to the full DPDP rules from day one.)
- Who is the Grievance Officer?
- Are child patients in scope at launch?
- Is teleconsultation in scope?
- Which lawyer reviews this map?

5. Sources

- DPDP Rules 2025 timeline: protectcomply.com/blog/dpdp-rules-2025-timeline
- Health data under DPDP: digio.in/blog/health-data-under-dpdp-why-hospitals-and-healthtechs-face-stricter-rules
- CERT-In 2022 Directions: psalegal.com/new-cert-in-directions-overview-and-implications
- Medical records retention: caho.in (Retention & Destruction of Hospital Records)
- ABDM HIP/HIU guidelines: abdm.gov.in